



Directory > ... >

Building zero trust architecture into your startup

Copy page



Building zero trust architecture into your startup

Last reviewed: over 1 year ago

Introduction

Most of Cloudflare's documentation (and, generally, documentation by most vendors in the space) is written with the assumption that adopting Zero Trust products will require shifting away from something. In scenarios in which nothing is built, or there is no tool that fulfills the goals which your team is trying to

accomplish, this can sometimes be confusing and alienating. New startups are especially underserved; as you focus all your energy on getting your business off the ground, it can be time consuming or confusing to read documentation that is angled towards enterprises undergoing network transformation.

This guide explains how to use Cloudflare to establish the foundation for a Zero Trust architecture early in the establishment of your security, networking, and development operations practices — with the goal of creating a sustainable, scalable business built on Zero Trust security principles.

The common principles for building a 'business' have fundamentally changed. Twenty years ago, this may have looked like getting office space (or a garage), buying some hardware infrastructure, servers, and user machines on which to begin building. As building continues, you add hardware-stacked firewalls and security appliances to create a corporate perimeter and protect the things that primarily exist in one place.

There's lots of good written content on the evolution of networking and security practices so we won't belabor the point here; the important detail is to recognize how the 'new' model matters for your startup as you build.

Chances are good that today most of your infrastructure will exist in a public cloud provider. Most of your code will be pushed and reviewed via common repository management tools, most of your developers will write code on MacOS or Linux machines, and will probably rely heavily on a form of containerization for local development. Within this model, Zero Trust security principles are just as relevant — albeit much easier to achieve — when your business grows into multiple complex functions, departments, and an expanding set of assets and data.

Using Cloudflare Zero Trust is a simple, (sometimes free!) way for startups to develop a comprehensive Zero Trust strategy that will grow organically with your business.

Who is this document for and what will you learn?

Cloudflare has lots of existing content related to migration and implementation of our Zero Trust product set. This document speaks directly to technical founders and founding engineers of young startup organizations who are looking to develop the framework for a modern corporate network, with modern security controls, from their first line of code.

In this document we'll explore:

- Getting started with practical Zero Trust remote access (ZTNA) capabilities
- Establishing sources of truth for identity, device posture, and learning how to use them
- Network building, both traditional and mesh
- Building Zero Trust into internal tooling
- Reviewing threats on the Internet
- TLS decryption and its relevance for your goals

- Exploring Zero Trust for your SaaS tools
- Navigating contractor and customer access
- Building with Infrastructure as Code

A few things explicitly not covered in this document:

- Introduction to basic Zero Trust terminology and concepts
- Recommendations for or against specific third-party vendor usage (while other vendors are mentioned in this document, it's purely illustrative and should not be taken as a formal recommendation from Cloudflare)
- Details on why you should explore adopting a Zero Trust security methodology (we have lots of good resources detailing that in the links below)
- Microsegmentation and autonomous Zero Trust concepts (these may be covered in future updates)
- Passwordless authentication (this is a cool and emerging space, and we'll provide some recommendations here in the future)

To build a stronger baseline understanding of Cloudflare, we recommend the following resources:

- What is Cloudflare? | [Website ↗](#) (five-minute read) or [video ↗](#) (two minutes)
- Blog: [Zero Trust, SASE, and SSE: foundational concepts for your next-generation network ↗](#) (14-minute read)
- Reference architecture: [Evolving to a SASE architecture with Cloudflare](#) (three-hour read)

Getting started — Foundational decisions

Asset inventory

Before thinking about your remote access or security goals, it's important to take stock of your current assets. Think about the answers to the following questions:

- What already exists and is in need of a sustainable model for security?
- If you have begun building infrastructure in a public cloud provider, how many distinct virtual private clouds (VPCs) have you already established, and how do they communicate with each other? More importantly, how and why do your users access those environments?
- Is it all through the console and browser-based management or terminal tools?
- Have you set up public IP access for some services over HTTPS or SSH?
- Are there resources that may allow access from the Internet that are intended to be entirely private?
- Have you established a traditional VPN to allow remote access to the environment, and how is it gated?

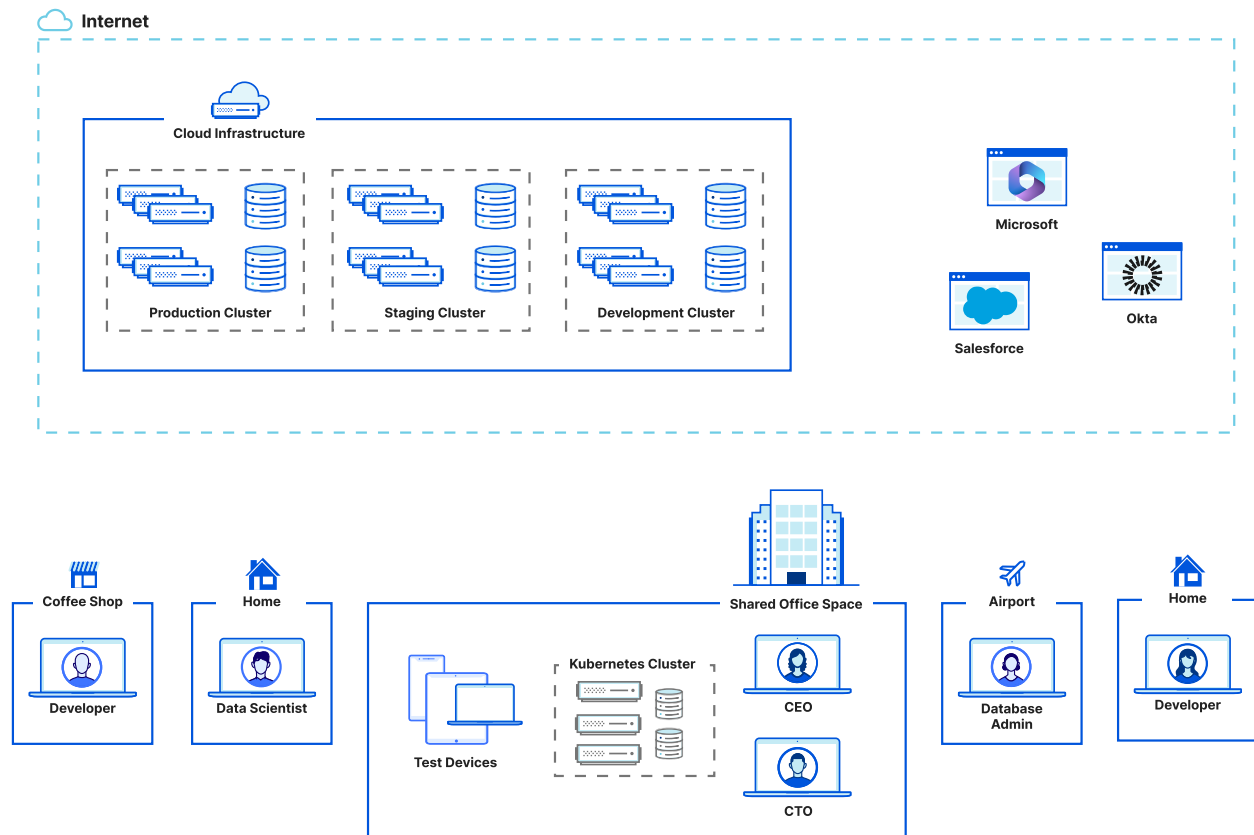
Next, build a map of your physical and virtual private infrastructure (essentially, anything that contains

company data). For many startups, this may just be implemented via a single cloud provider. Note all the resources in that environment that are accessed, either by human users, other infrastructure, or public or private APIs — then document the purpose of each service that sees regular traffic. As you do so, try to answer the following questions:

- Is this an internal web-based tool built to monitor your build pipeline?
- Is it a self-hosted analytics tool like Grafana, or a supporting metrics server like Prometheus?
- How are users reaching that service — via a public IP, a private IP, or a local path?
- Are users able to reach the service from other cloud environments or VPCs? If so, how are they connected?

Once you've developed a comprehensive list of your existing resources, this will serve as an asset inventory for your development of a Zero Trust architecture. If you don't know what you need to protect, it'll be

difficult to protect it, no matter how many security tools you have.



A valuable third step may be to begin stack-ranking these services by risk level in the event of a breach, to later determine the specificity of your security policy. For example, your internal tool to alert on build status may be a level 3, but your production database for customer information would be a level 1. A level 3 application may be able to be accessed by a user on their own device, assuming they can meet your identity

control requirements, but a level 1 application may require access from a corporate device and the use of a specific kind of multi-factor authentication (MFA).

Note

If you've already grown to the point that documenting your asset inventory is very difficult or time-consuming for your business, you can use tools like our [Private Network Discovery](#) capability to build a sense of what your users access in your network space.

Common goals and outcomes

Many startups that use Cloudflare are encouraged to adopt a Zero Trust security posture by external sources: investors, partners, vendors, risk analysts, or compliance officers. Even if this is a project or evaluation that is driven by outside parties, you can still establish common goals to ensure it drives a measurable, desirable impact.

Some common goals we hear from customers:

- Make internal tooling easy for our users to access securely
- Build security into the development pipeline
- Adopt increased security without sacrificing user and work experience
- Define and execute a bring your own device (BYOD) strategy
- Simplify management of networks and application access
- Protect data in SaaS applications and on the corporate network
- Ensure auditability (“a quick view of what's happening, who's doing it, and if it's okay”)
- Demonstrate security best practices to our customers and end-users

It's also possible that your goals may be simpler or more tactical than this; for instance, adopt a modern remote access tool, securely connect my internal

networks, or only allow corporate devices to connect to my Gitlab Enterprise tenant. Whatever your goal, the most important element in goal-setting will be to establish what you need now and balance it against what you may need or expect to need in the near or mid-term future. If you intend to grow significantly, expect to sign customers with demanding security reviews, or be prepared to apply for a new compliance certification, such as SOC II or PCI. In order to accomplish this, it is crucial to start with a Zero Trust vendor, which can help layer on additional security tooling and capabilities without exponentially increasing complexity or cost.

Goal-setting is also an important exercise for prioritization. If you know that your primary goal is to *identify and put identity-aware security in front of all our internal services*, but that in the next six months you intend to *restrict BYOD usage to level 3 applications*, your first goal will need to strategically support the execution of the second. Understanding the stack-rank of priorities over the next few months

(knowing things change quickly in your startup!) can save you the time spent in re-architecture discussions, or unraveling technical or commercial decisions with vendors that fit your needs in the short term, but not the mid-term.

Identity

Identity is at the core of every Zero Trust strategy. Ultimately, most customer goals revolve around using a central source of identity to authenticate, validate, and log all actions taken by a user, spanning both 'owned' (hosted, private network) applications and SaaS applications. Identity (through an SSO provider, for example) can then be used to layer additional security controls like multi-factor authentication, or phishing-resistant authentication.

One of the most important things you can do early is to coach users to become accustomed to using multi-factor authentication. Phishing-resistant MFA options like physical keys, local authenticators, and biometric

authentication have been credited by Cloudflare as a major factor in [stopping the attempted breach ↗](#) that affected Twilio and other SaaS companies in 2022.

In the context of getting started with Zero Trust, the type of identity provider that you decide to use (Google Workspace and Microsoft Entra Identity being the most common) is less important than your implementation strategy. As long as you have a directory that is secure, allows for phishing-resistant authentication methods, and is designated as your source of truth, you have the necessary components to integrate with a Zero Trust vendor like Cloudflare and deliver continuous interrogation of that identity-as-security posture for all of your corporate tools.

SSO integration

Many directory services also provide single sign-on (SSO) solutions for integrating directly with SaaS applications. While this is a simple and logical choice, many enterprise applications make SSO integration a challenge, and onboarding a critical mass of SaaS

applications to any one directory service can drive vendor lock-in. As your organization continues to grow, your identity strategy will inevitably change and mature, and it's important to maintain flexibility to address unexpected challenges, like some of the vendor breaches that we saw in 2023.

Along with the challenges related to flexibility, many SSO providers have yet to fully integrate device posture concepts into their 'source of truth' model. Some vendors like Okta offer machine certification as part of an authentication event, but it's limited to Okta's FastPass product and doesn't include signals from other sources or vendors to better determine what constitutes a corporate device.

Third-party access

Finally, you will not always own the identities that are used to access your systems. You may hire external auditors who need to use their own company identities to authenticate. You may decide to allow contractors to use their existing GitHub identities to access private

GitHub repositories. There may be times where you simply need to provide access to someone with just an email address to access a low risk resource, such as showing customers a preview of a new product interface. So your Zero Trust solution needs to allow identities beyond your central directory to also gain access.

Where does Cloudflare fit in?

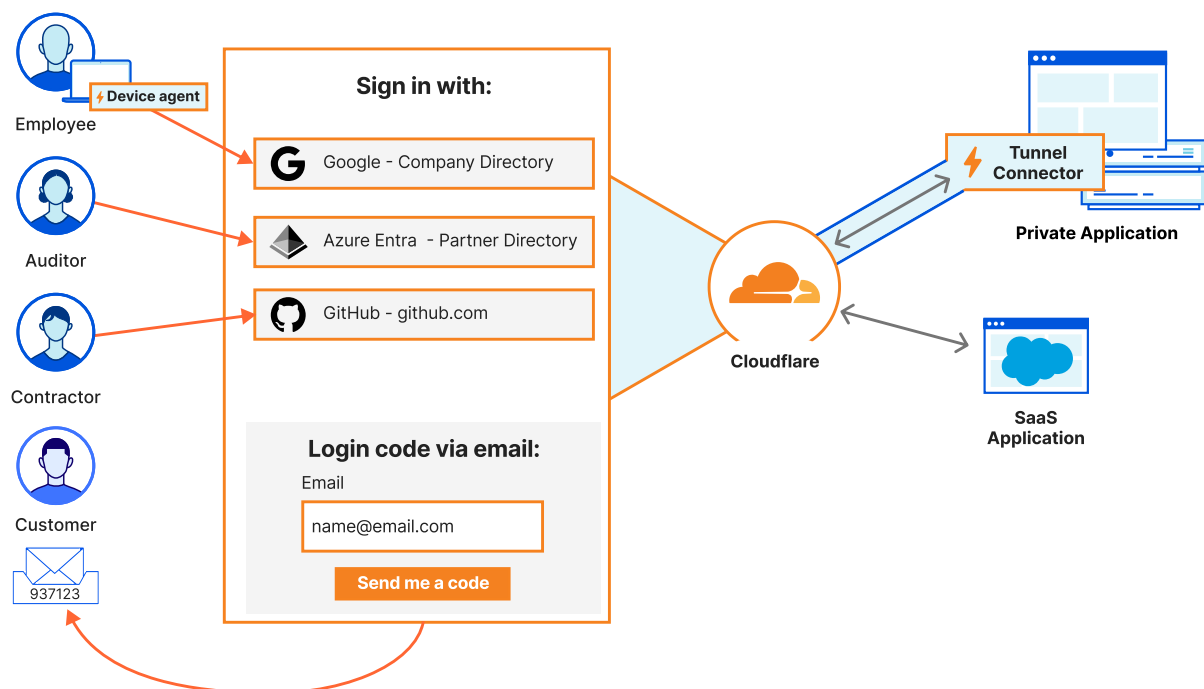
Later in this document, we'll describe using Cloudflare Zero Trust to protect your internal applications, and how to use Cloudflare as your SSO in front of your SaaS applications to deliver a simple, unified security posture everywhere.

Cloudflare *matters* in this case because once you've determined a source of truth for your identity provider, you need tooling to perform continuous authentication against your user population. This tooling is difficult to build and maintain, as evidenced by a number of well-known technology companies who retired their internally-built Zero Trust proxy and switched to

Cloudflare in 2023, citing management complexity and an inability to add new security functionality.

Cloudflare can simplify your architecture by becoming the singular enforcement point for your identity against your private applications, your networks, your developer services, and your SaaS applications.

Cloudflare is one of the only vendors to be able to provide Zero Trust authentication concepts as a web proxy (layer 7 services), as a VPN replacement (layer 3/4 services), and as a secure web gateway.



Device posture

As your business grows and you begin to operationalize the distribution of endpoints to your user population, device posture is a key component of a strong Zero Trust strategy. Once you've validated your users' identity posture, there are other actions you can take to further reduce the risk of a data breach. Consider this: even if your user is valid and has an active identity session, their device could theoretically be infected, and attackers could benefit from (or *hijack*) their valid identity session.

Companies use device posture to prove that a connection is coming from a trusted device. Let's look at the theory behind device posture before listing some common strategies and approaches to getting started. In this example, you have sensitive data located somewhere in AWS. This data is critical to the operation of your business. It is (rightly) protected behind identity-aware authentication, so you feel confident that it can only be accessed by users with the

proper identity posture. Your users are all remote, and connect to AWS from Macbooks that are pre-configured with your endpoint detection and response (EDR) software of choice. Users on their Macbooks, configured with enterprise EDR software, have a lower risk of potential breaches than when they use their personal laptops to access company data. But how do you prove that your users with valid identity posture *only* access your sensitive data from the devices that contain a lower risk of breach?

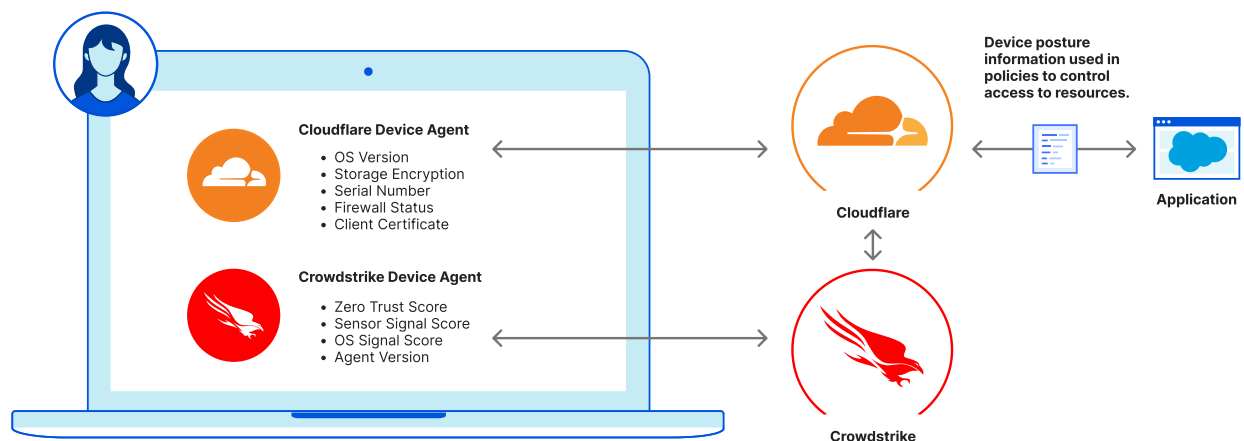
As your security organization grows and you begin to implement data loss prevention (DLP) strategies and tools, this becomes doubly important. If your users can theoretically access sensitive data without applying a burden of proof to the device used for access, users may be able to (intentionally or inadvertently) circumvent your security tooling and create the risk of exfiltration, or at a minimum, blind spots for your visibility and auditability.

Common device posture strategies usually rely on a combination of an endpoint management tool (like JAMF, Intune, etc.), a corporate certificate, and security tooling like EDR software that might sit on the device. Some of this tooling can fingerprint your devices in a way that can be externally validated where supported. In order to achieve Zero Trust access controls with device posture validation, an endpoint agent from the Zero Trust vendor typically needs to be deployed on the devices. Then, it is used to 'independently' verify a claim from a third party vendor before applying that device state to be used in a policy. When evaluating vendors, it is important to evaluate their ability to poll for state relatively frequently, so that they are adhering to the Zero Trust policy philosophy for “continuous evaluation” of state.

Where does Cloudflare fit in?

As you begin to use third-party vendors for Zero Trust security outcomes, those vendors need to ingest first-party signals to help you make the best security

decisions. In this case, Cloudflare becomes your point of policy enforcement for device posture — in addition to identity posture. The Cloudflare device agent will evaluate your device ownership or health metrics, and use them in conjunction with policies about user identity to ensure access to sensitive resources both has proper identity verification and is coming from a compliant device with the acceptable level of security control.



Traditional and mesh network building

In the 'old world' model (also known as a castle and moat security architecture), your infrastructure would probably be homogeneous and protected by a firewall. To access network resources, users not in the office (or other third parties, vendors, etc.) would need to connect to the network via a VPN and firewall, or use another available network route via a public IP address. Because most infrastructure now lives in the cloud, and most startups begin remote-first, almost none of the traditional networking concepts will be explicitly relevant as you design the initial phases of your 'corporate network'.

In this more traditional networking model, your infrastructure will probably be structured in several of the following ways:

- It will exist in one or multiple VPCs (which may or not be connected by cloud provider transit gateways)
- The addressing of your services will probably be managed by your cloud provider

- You will use internal DNS from a cloud provider like AWS' Route53 DNS (most businesses still rely on internal DNS to some extent, no matter how cloud-native they may be)
- There may always be a reason to maintain some concept of a privately networked space, as long as you maintain your own infrastructure
- It's possible that all users won't have a need to understand or navigate using your internal DNS infrastructure (but technical users and services likely will)

As you begin establishing patterns in the infrastructure that you build, it's likely that you'll collate around a single, primary cloud provider. The main concepts relevant for this document will focus on users connecting to your network to access internal resources and services, and the way that your internal services communicate with the Internet broadly. Management of cloud infrastructure permissions and policies, as well as recognition of the ways in which your internal services can communicate with one another is equally relevant

to a comprehensive Zero Trust strategy, but will be discussed in depth in future updates to this document.

Connecting users to networks

This will probably be one of the most common Zero Trust use cases for a majority of startups. You may be asking yourself, How can I get my user access to my internal network or application without managing VPN hardware or exposing my business to risk? As you navigate the best way to connect your users to your private networks and services — while still adhering to Zero Trust principles — there are two important things to consider:

1. **Limiting exposure** — A Zero Trust philosophy encourages organizations to limit the amount of ways in which networks or services can be accessed. Having public IP addresses or ingress paths into your network can introduce unwanted risk. This is typically accomplished by using outbound-only proxies that connect to Zero Trust

vendors to only proxy authenticated traffic into your network, and do not require any public IP access of any kind.

2. Limiting lateral movement — One of the best ways to reduce the radius of a potential data breach is to practice least-privilege access for all resources. Least-privilege access is a core tenet of a Zero Trust architecture, in which users only receive the level of access they need for their role, rather than getting carte blanche access to the entire corporate network. The most analogous concept as it relates to Zero Trust frameworks is that of 'microtunnels' — a recommended approach in which each application or service that needs to be accessed receives its own distinct 'route'. Similar to microtunnels, least-privilege access enables you to build a practice in which only explicit services and users have access to specific resources, helping position future security organizations very favorably.

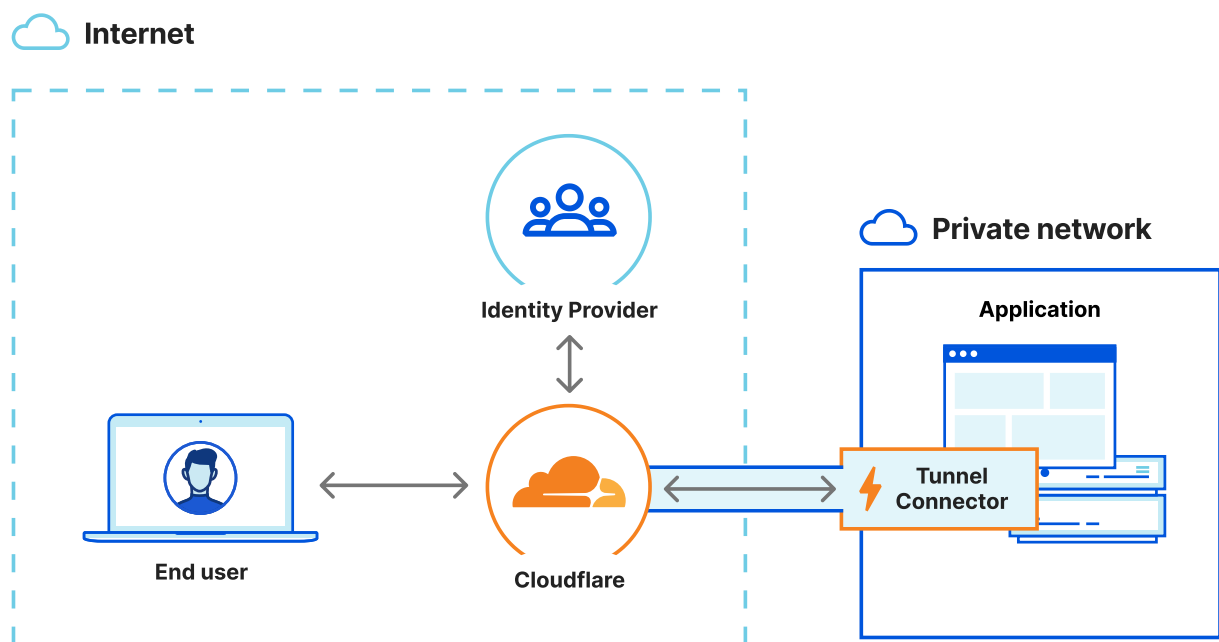
Defining a clear strategy for infrastructure creation and management — along with a predictable internal IP and DNS record structure — will be invaluable for accessing and protecting your assets as your organization continues to grow. A little later in the document, we'll expand on the ways you can use automated workflows to create infrastructure that can instantly integrates with your chosen Zero Trust security provider. It will be significantly easier to layer security policies over your access control models if you have a continued, clear sense of what infrastructure exists and how it is currently addressed.

Where does Cloudflare fit in?

Cloudflare Zero Trust can make private networking concepts extensible to your end users with a combination of endpoint software and cloud networking connectors. In this case, you can use Cloudflare as an 'overlay' network to extend secure access to your internal network for end users without exposing public IPs, allowing ingress from your cloud

environments, or introducing any sort of additional risk that usually comes with remote access.

With this 'overlay' network, a small piece of software sits in your network and provides both 'network' tunnels (to give users administrative access to services on your internal network, replacing traditional exposed-bastion concepts) and 'application' tunnels (micro-tunnels that will only allow an authenticated user to explicitly reach the singular service defined in the tunnel).



This makes it significantly easier to manage user access to multiple, distinct private networking environments

without forcing the user to change their profile, switch settings, or constantly disconnect or reconnect from one or multiple clients. It also gives you the capability to easily expose a single private application or service to specific audiences while adhering to Zero Trust principles.

Connecting networks to networks

For most startups, networking is not at the top of their list of things to change. Typically, businesses follow the path of least resistance, which typically involves managing connected VPCs in AWS or GCP, and maybe setting up a few external connections to physical locations. Most businesses, however, find that their growth results in an increasingly complex network topology — a process that tends to happen very quickly.

When simplifying the corporate network, some common extensions may include customer networks, partners, multi-cloud, acquisitions, disaster-recovery planning, and more. As your security organization matures, there will be more and more reasons to spread infrastructure across multiple VPCs (even within the same cloud environment). And, as security groups for those VPCs become increasingly complex, you will find that you are managing multiple internal networks with distinct policies and sometimes distinct operations.

As these network extensions become more relevant for your business, it's worthwhile to review which connectivity options make the most sense, and explore strategies to build a functionally complex, fundamentally secure network.

Traditional connectivity

The traditional methods of network connectivity still have significant value both in physical and in cloud

environments, but using them efficiently while maintaining an effective security perimeter can be a challenge. When businesses only had physical connectivity requirements, like branch offices or supplemental data centers, the framework was much more simple. You'd use either edge devices like routers or firewalls to terminate physical connectivity, or a dedicated head-end device to build VPN ("virtual") network connectivity between the sites. Essentially, you would be connecting two 'networks' together by providing a new route to a new network or subnet for all the machines on your initial site.

In addition to creating WAN connectivity, the end goal of bridging multiple sites is management simplicity. Having a unified network means that it is easier to support network functions like edge routing, gateways, and addressing via DHCP. However, this can also result in overly-broad policy management, and it can be difficult to manage the security implications of increasingly growing networks with increasingly complex edge cases and unique scenarios.

For modern startups, the problems may not be the exact ones described above, but you will likely still have to solve for growing network complexity. The best way to navigate this is to *plan effectively*. If you begin building your corporate network with security and scalability in mind, you will be able to easily solve increasing complexity as your security and IT organizations grow.

Mesh connectivity

While traditional networking concepts primarily focus on connecting networks to one another, mesh or peer-to-peer networking concepts connect networks to assets or independent endpoints (e.g. end-user devices, like laptops and cell phones, or IoT devices, like smart lights and security cameras).

In a traditional network, you may have a VPN tunnel that creates a site-to-site connection between the IP spaces of 10.0.0.0/8 and 192.168.0.0/24, giving all devices within either network a gateway to

communicate locally with devices on either network. Conversely, in a mesh networking model, you may only want certain IP spaces to communicate with each other — for instance, enabling 10.2.3.4 to communicate with the device that has the IP address 192.168.0.50.

If you only operate with 'micro-tunnels' (e.g. discrete X can only reach discrete Y), you massively reduce your opportunities for lateral movement. For example, using a mesh networking model means that IP address 10.2.3.4 would not be able to reach sensitive data on a different 192.168.0.0/24 address (although it might be able to within a traditional network model). However, this increased security posture also results in increased complexity. Not only do you (usually) need to manage agents on each relevant endpoint in a mesh network, but you then need to be prepared to build and manage discrete policies for each asset and connectivity path.

Editor's note

In some analyst circles, the mesh connectivity space is beginning to be referred to as 'Secure Networking', and while we appreciate the opportunity for differentiation, Cloudflare believes that there are methods for making both traditional and mesh networking effectively secure.

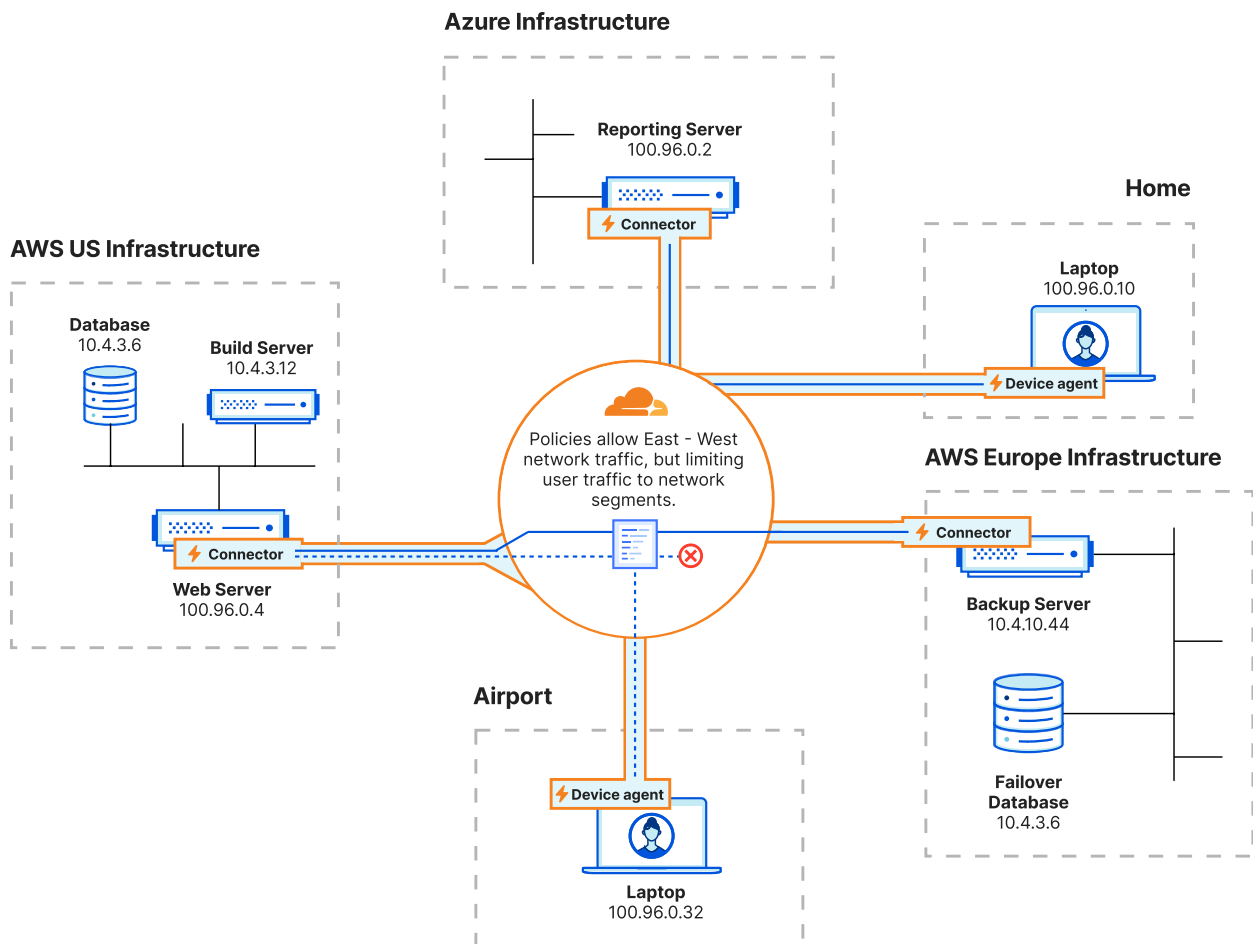
Where does Cloudflare fit in?

If both operating models sound complicated and imperfect, it's because they are. Because of this, Cloudflare believes that a blend of the two is typically the right approach for businesses of all sizes.

If your organization is experimenting with mesh connectivity, Cloudflare can help support discrete connectivity models while layering in unique identity concepts and supporting your security and scalability

needs as you construct a networking framework to support your future growth.

The Cloudflare products that are typically most relevant for startups are a combination of our WARP client (via `ccloudflared`) and Cloudflare Tunnel (via WARP Connector). This allows you to manage remote access, mesh connectivity, and traditional networking connectivity from a single dashboard. On a more granular level, this means you can configure device posture information, identity information, client certificates, and common L4 indicators (like port, IP, and source/destination protocols) from a single point of policy enforcement — enabling you to build robust security policies for both human and autonomous network interaction.



This blend of networking models is designed to support a wide range of use cases, whether you are trying to provide remote access to your corporate network, extend your corporate network to encompass cloud environments on on-premises equipment, or continue building out a model for mesh connectivity between critical infrastructure without introducing additional risk or overhead.

Building Zero Trust into internal tooling

Among almost all the startups (and mature companies) that Cloudflare has worked with, security for internal tooling continues to be a ubiquitous challenge. You may build tools that you need to accomplish tasks specific to your business, or you may choose to self-host or use open source software — which can also be consumed as popular SaaS applications for services, monitoring, or other functions.

The principles outlined in previous sections address methods of managing remote access to these resources and deal primarily with authentication. In summary, achieving a Zero Trust model in practice requires you to ensure that access to each internal service is controlled by a continuous identity authentication proxy, ideally one that is physically separated from your network perimeter, has clear auditability, and offers the capability to quickly revoke user access as needed.

However, one of the biggest challenges businesses face as they begin to implement a Zero Trust model is not authentication, but authorization. Getting the user to the front door of your application in a Zero Trust model is (relatively) easy, but managing their credentials for both authentication and authorization, ensuring that the two match, and simultaneously maintaining a positive, non-invasive user experience can be very difficult.

In an ideal world, we believe that authentication and authorization should be handled by the same service. This would mean that while deliberating how to secure your internal applications — whether to build OAUTH capabilities into them directly or to integrate directly with the primary SSO that you use for your SaaS applications — you would also consider how your authentication methods may conflict or become duplicative with your identity validation methods. There are two primary ways to use these concepts to set yourself up for scalable success with authentication and authorization.

Consuming Zero Trust vendor tokens

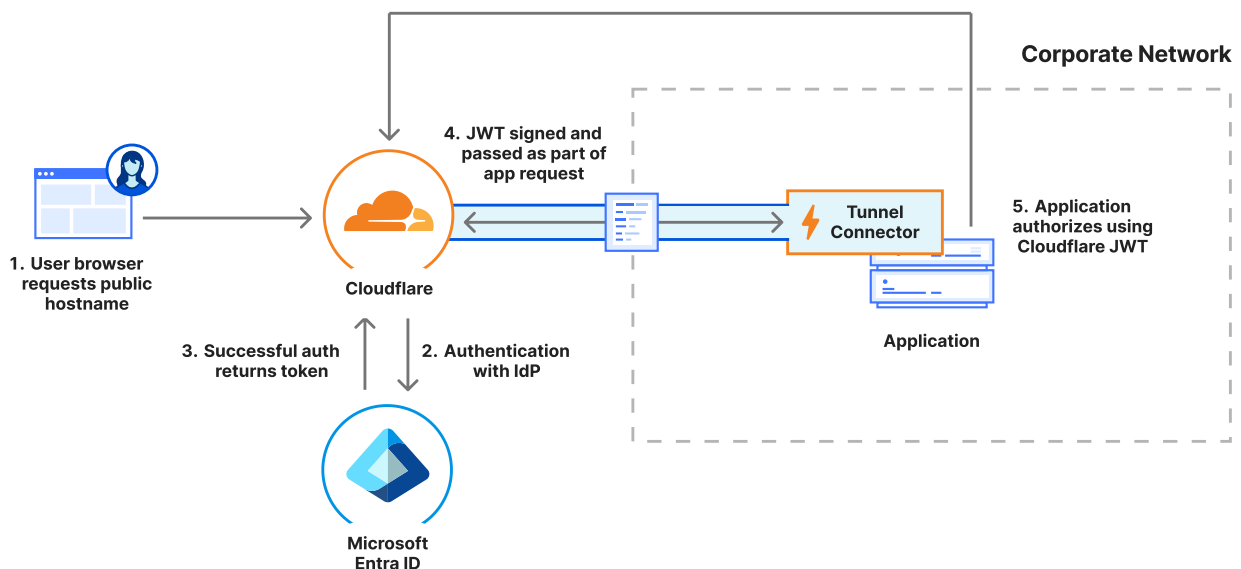
'Vendor tokens' is a concept that does not exist for every Zero Trust or SSE vendor. This is due to Cloudflare's relatively unique approach; because we're the world's largest provider of authoritative DNS, we provide DNS for the 'external' path to your internal applications, then create tokens for user access.

These tokens are based on the information Cloudflare receives from your identity provider after a successful authentication event, which matches against custom policies for that application. Each token contains all of the content that would be signed in a user's authentication event with their IdP: their name, username, email, group membership, and whatever other values are present. It also gets a unique tag to indicate its relevance to a specific application.

Once the *Cloudflare* token has been created, it is passed to your internal applications to validate their requests and authorize access to your internal tooling.

This takes minimal additional work per-application, and can be built into application creation workflows where you would otherwise need a complete OAUTH integration or SSO integration.

By using Cloudflare tokens, your users will have a seamless experience both *authenticating* through your established Zero Trust proxy and getting *authorized* directly into your application with the same information.



Your Zero Trust vendor as an SSO

Some Zero Trust vendors provide the capability to operate as an SSO provider, integrating directly with your applications (like open-source or self-hosted solutions) which come with a pre-built SSO connector. In this flow, your SSO controls your authorization to the application, and your Zero Trust vendor calls out to your identity provider to make authentication decisions, without needing to manage multiple primary directories.

For Cloudflare users, this offers a number of advantages: it helps streamline authentication (AuthN) and authorization (AuthZ), reduces your reliance on a specific SSO vendor, and allows you to use multiple simultaneous authentication providers. Most importantly, it enables you to easily adopt or switch to a new identity provider. Businesses may not use the same identity provider at 25-50 users that they use at 300-500+, and there is always significant friction in the hard cutover required to move from one SSO integration to another. This transition can be especially difficult considering the time and frustration present in

some applications' SSO integrations. Using Cloudflare as an SSO provider can help alleviate that friction by aggregating all of your identity, device posture, and risk integrations within a single policy enforcement point — thereby helping you streamline your AuthZ/AuthN and put additional security controls in front of your self-hosted applications.

Where does Cloudflare fit in?

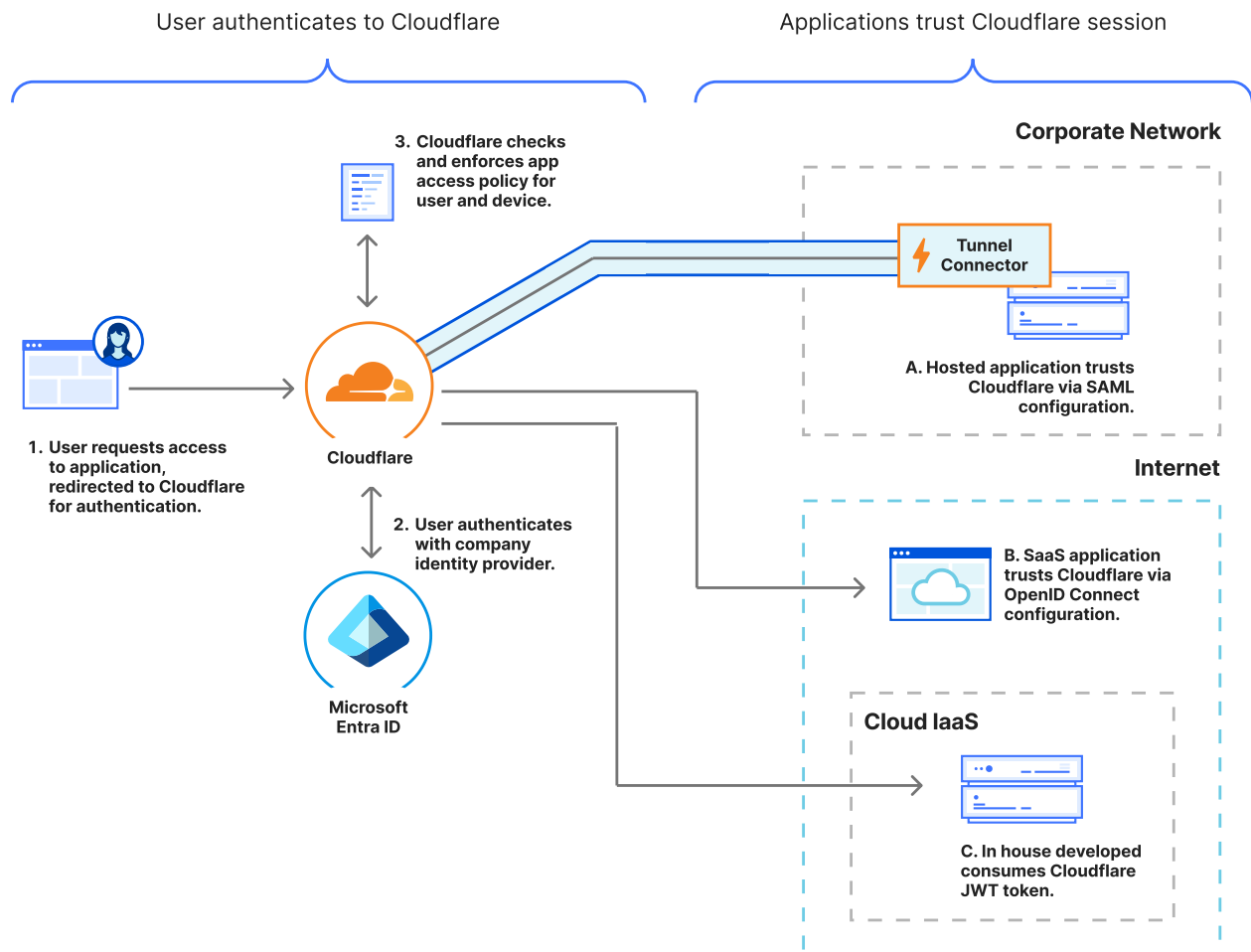
We recommend using our Cloudflare Access product for remote access to your internal services (by way of our Cloudflare Tunnel software in your network). With Cloudflare Access, you can [consume the JWT](#) created by Cloudflare Access or use [Access for SaaS](#) to act as a SAML or OAUTH proxy for your private, self-hosted applications (which have SSO integrations pre-built into them).

In a lot of cases, you may even use both products for application access. For example, if you're self-hosting

[Sentry ↗](#) — which is not currently available on the public Internet — follow these steps:

1. Set up a public hostname with Cloudflare Access (which your users would navigate to Sentry on).
2. Install a Cloudflare Tunnel with an associated **Published application** to point to your local Sentry service.
3. Integrate Sentry with Access for SaaS as the SSO provider.

Now, users reaching the application from outside your network will already carry the Cloudflare JWT, and will be seamlessly authenticated into your application.



Remote access for contractors, vendors, and customers

Established and accepted patterns for corporate user remote access don't always extend to heterogeneous sets of users, which usually include contractors, third-party vendors, and even customers. All these user

groups can have valid reasons for engaging with your private resources. It's possible you may hire development or maintenance contractors that need access to some parts of your network or applications, but providing them complete network access would introduce unnecessary risk.

It's also possible that you may provide hosted or managed services to your customers that they would then deploy within their own networks. In that case, you may need to connect with those services to appropriately manage them. Or, subsequently, you may host private resources for customers within your own environment and need to give them secure access to only access their relevant tenant.

Establishing scope

Whenever you determine a need for third-party user access to your environment, you should first determine three attributes:

- What they need to access
- What level of authentication is required for that access
- How long this access will be relevant

Web access for third parties

After determining the scope, you should determine the least-privilege access model appropriate for the user group. This may mean integrating with a secondary identity provider (maybe the customer or vendor's IdP) to use in authentication events, or using a temporary authentication method like a one-time PIN to authenticate against their email address only.

Some businesses also add vendor and contractor users to *their* identity provider to streamline authentication and to control methods (like the use of MFA and other authentication factors). At a minimum, we recommend working with a Zero Trust security provider who supports multiple, simultaneous methods for

authentication, and can apply them via specific policies or applications.

This allows you to keep all of your existing methods of secure remote access consistent. Your external user cohort will use the same paths into your network and will be subject to all of your security controls.

Meanwhile, you will receive detailed logging and audit trails to dictate exactly what users had access to, how frequently they accessed them, and what kind of actions they took within your network. Assigning least-privilege controls can also easily establish an access model while ensuring that users aren't able to perform any lateral actions or access resources within your network unnecessarily.

Administrative or network third-party access

If this access can't be established over a web browser and needs network-level controls, your external users may need to deploy the endpoint agent used for your

Zero Trust deployment. For example, contractor groups often have multiple endpoint agents connected to a single user machine, which can introduce network routing complexity — or even conflicts, if some of these private networks overlap across different businesses.

To ensure a simple, manageable process for ensuring third-party access, consider the following:

1. **Can your Zero Trust vendor support multiple profiles for endpoint agent deployment?**

Contractor users should have tightly-scoped routing controls to ensure limited access to your network and limited risks of conflict with other agents on the device.

2. **Is third-party access materially different from corporate user access?** If not, you can streamline your administrative management activities by building functional identities and integrations for third parties. New policies may not necessarily

need to be created, as long as everything can be audited and differentiated.

Access to customer environments (and vice versa)

In some cases, corporate users need secure (persistent or temporary) access to customer environments, or customers may need similar secure access to unique, hosted environments within your network. This process may include hosting software tenants for customers, running maintenance on customer-hosted software, or providing connectors for product functionality that ties into customers' internal networks.

For these use cases, the traditional recommended model has been a networking configuration like site-to-site VPNs and similar options. These can be scoped appropriately, but often result in overly broad connectivity between your corporate network and your customer network, and can introduce risk or overly-broad access capability.

In a Zero Trust security framework, this kind of access should be explicitly scoped in a least-privilege model. This can be accomplished by setting up identity-aware or service-aware site-to-site connectivity, or by using unidirectional connector models to provide secure access in either direction, which can be scoped to specific actions.

Where does Cloudflare fit in?

Cloudflare can help provide scoped secure access for both web and network connectivity to your third-party users in a Zero Trust framework.

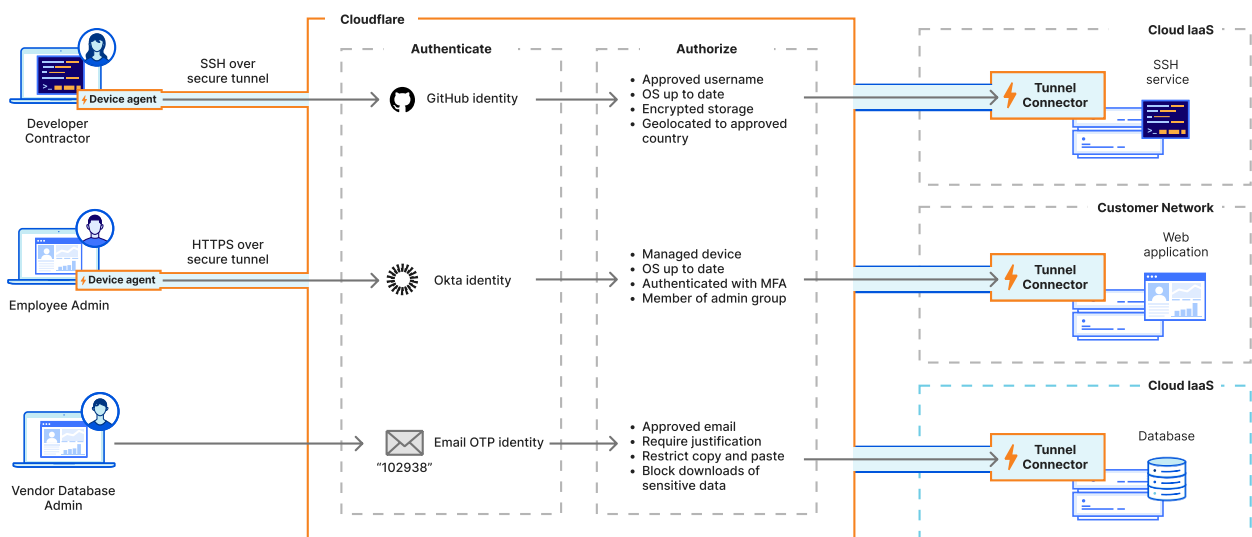
- **Cloudflare Access can integrate and use [multiple identity providers simultaneously](#).**

This can be scoped to a single application and a singular policy, and can have granular capabilities to 'force' some user access to authenticate in specific ways. There are also many third-party specific workflows — like [purpose justification](#) — that can ensure that user access is both easy for

third parties, and documented and controllable for administrators.

- **Cloudflare Zero Trust can be deployed with flexible endpoint agent parameters and [logical groupings](#) for contractor and third-party users.** If you have external users with internal access needs, they can be both tightly-scoped and limit potential conflict with other external systems.
- **[Cloudflare Tunnel](#) can act as a unidirectional access model to provide corporate users access to scoped customer resources.** It is lightweight, easy to deploy, and can even be built into your deployment packages and deployed alongside the services you manage in customer environments.
- **Cloudflare WARP Connector can help you build secure, extensible networks relevant for each of your client controls.** This is particularly helpful when bidirectional (site-to-site) traffic flows are a necessity for the way that you engage

with your customers, interact with their applications, or address other management concerns. WARP Connector has all of the same inline security policy application and auditability controls as the rest of your deployment, so you can maintain a Zero Trust security posture while achieving customer connectivity.



Protecting against Internet threats (or, *is secure web gateway a part of Zero Trust?*)

Traditionally, the concept of Zero Trust access has been explicitly relegated to user or machine access to internal or privileged resources. On a functional level, this requires replacing network extension, reducing over-permissioning, and minimizing lateral movement and threat vectors typically delivered from VPN remote access connectivity. But for many businesses, their VPN didn't only proxy their private network traffic. It also managed their Internet traffic and allowed them to maintain a unified view of threats — typically, either through a module to send DNS queries to a cloud provider, or by simply backhauling all user traffic to the corporate network to be sent through the corporate firewalls.

The security and complexity challenges introduced by this castle-and-moat model has forced many vendors to address the two primary functions a VPN serves. Now, it is common to hear secure web gateways (SWG) and Zero Trust access (ZTNA) discussed in the same sentence or as part of the same product.

Although this shift was driven by vendors and analysts, rather than security researchers, it has seemed to improve security manageability for customers while simplifying the buying and deployment process for startups. Namely, deploying a single agent to handle both your corporate and Internet traffic is a significant improvement over using multiple device agents to handle all sorts of security tooling.

Long Live The New Perimeter

In the old world, your perimeter was denoted by your public egress IP address, and indicated that you were subject to a series of security controls before your traffic went out to the Internet. Maybe it was a firewall, IPS, IDS, or something else. For that reason, businesses began requiring a specific source IP for traffic before it could be 'trusted'; this was used with vendors, third parties, and SaaS applications. Traffic originating from the corporate network (with your corporate source IPs) was one of the biggest indicators of 'trust'. It's no longer that simple.

Today, it's likely that your business has no central 'perimeter' at all. It likely started in the cloud, ships out user endpoints either raw or with some pre-configured security control, and runs everything remotely and asynchronously. This model is highly impactful for your productivity and ability to scale. However, as your security organization grows and matures, there will be an inherent benefit to setting a baseline security 'posture' that will denote the new perimeter.

A perimeter-less model

In a world in which your Zero Trust provider and your SSO should be able to protect most of your private applications, networks, services, and SaaS applications, users should be more empowered than ever to work from anywhere — and your asynchronous, highly-effective style of work shouldn't need to be interrupted if you follow best practices. In other words, **your definition of a 'secure' endpoint becomes your new corporate perimeter.**

A defined secure endpoint, with clear measurability is significantly better for security posture because, unlike a source IP address, it's both highly targeted and continually validated. In the old world, this would mean egressing through a firewall and being subject to security controls. In the new world, this typically means verifying encryption, interrogating posture on the device, and determining whether or not the traffic coming from the machine was inspected by a secure web gateway. It could even still include source IP address as a method of validation, but never as the primary control.

As you think about how you want to manage the usage of BYOD (and how you want to ensure your corporate data is being accessed securely), you just have to make a determination about what constitutes your secure endpoint strategy. Then, consider how you should interrogate requests to sensitive resources to ensure that they are compliant with this strategy. For instance, think about the steps users will need to take in order to access Workday (or another PII-heavy system). Before

granting access, you may want to send their traffic through your secure web gateway and apply data loss prevention policies. Now ask yourself, what other steps do you need to take in order to enforce these requirements?

Within this discussion, we are thinking about Internet security (e.g. secure web gateways, DNS filtering, traffic proxying, and so on) as a set of advanced security signals from which you can apply more accurate, granular Zero Trust policies for your sensitive resources. It's also a good practice to get started with DNS filtering as soon as possible, since deploying software and proxying traffic from your endpoints will only become a more complex process as your business and security needs grow. As you start to think about other advanced security controls, like HTTP filtering and data loss prevention, we recommend reading [Getting Started with TLS Decryption](#) ↗ to get a sense of the decisions to be made before decrypting traffic.

Where does Cloudflare fit in?

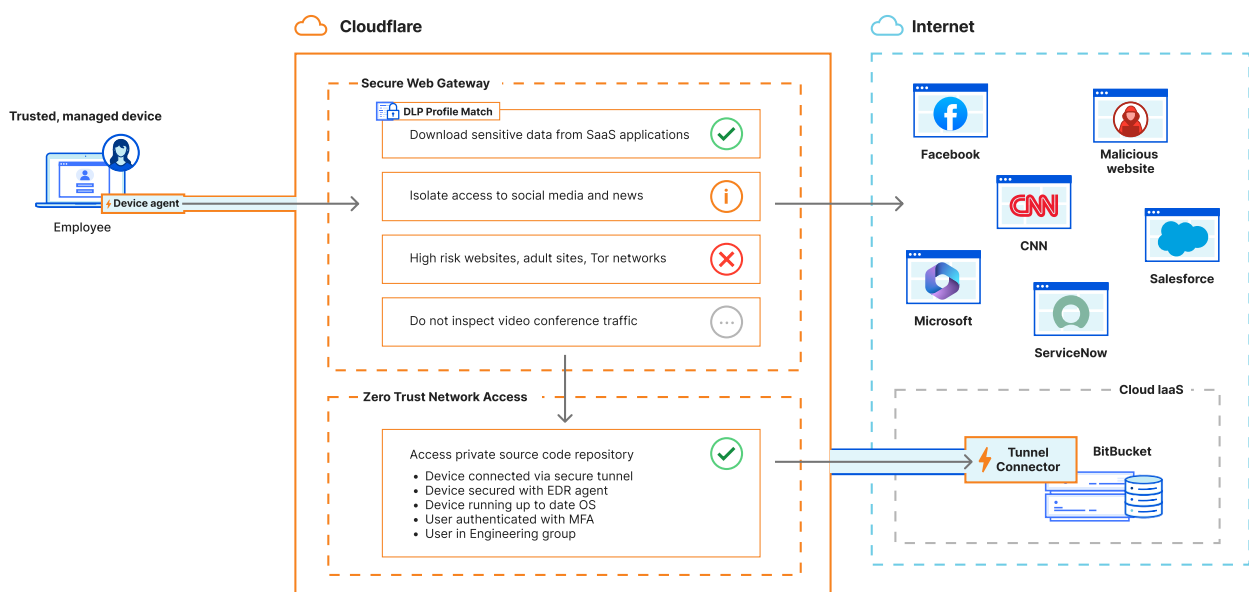
In addition to providing Zero Trust security capabilities for internal applications, network remote access, and SaaS applications, Cloudflare also provides the following functionality:

- DNS filtering
- An L4 firewall
- A secure web gateway (SWG) — complete with application-awareness, TLS decryption, data loss prevention, CASB functionality, browser isolation, and the ability to adopt a dedicated egress IP structure directly from the Cloudflare network

All of our SWG functionality is controlled via policy that factors in user identity, device posture, and user risk, and is delivered from the same endpoint agent as your Zero Trust controls — using the same policy engines and policy enforcement opportunities.

Cloudflare allows you to functionally build a new perimeter by identifying, applying policies to, and securing the outbound traffic on your managed endpoint devices. You can achieve the same unified

security control as the old castle-and-moat perimeter, while applying independent, granular security evaluation (but without backhauling any user traffic). Then, you can use that security evaluation to apply even stronger controls from your Zero Trust-protected applications, helping you distinguish between low, medium, and high risk users, make determinations about how to handle BYOD traffic, and more.



Adopting and securing SaaS applications

The concept of SaaS security means a lot of things to a lot of people. For that reason, it's a somewhat controversial topic, especially as it relates to Zero Trust. SaaS services saw huge user population booms during the first wave of COVID, due in large part to a significant increase in remote work. Almost overnight, it was easier and more practical for users to connect to services that existed outside of corporate infrastructure than it was to connect to internal services.

Some make the argument that SaaS applications are either 1) inherently secure when you've integrated SSO, or 2) are the functional responsibility of the SaaS provider to secure. While these arguments address the way in which your SaaS investment is accessed and secured, they do not contextualize why companies use SaaS — which is typically for storing corporate information. The proliferation of 'places your sensitive data may live' will be an increasingly important factor in your SaaS security decisions.

The above statements all imply that you know what SaaS tooling your users engage with, but often that is not the case. First, we'll address 'sanctioned' SaaS adoption, and then we will discuss concepts related to 'unsanctioned' SaaS (also known as shadow IT).

Sanctioned SaaS applications

Determining your required security posture is an important first step for your end users before you build any sort of security policy. So, if you have applications which contain significant amounts of corporate data or other data subject to compliance laws or other regulations, it may make sense to restrict those exclusively to devices that fit your aforementioned 'perimeter'.

The best way to accomplish this is to find an aggregator of your signal (like Cloudflare's Access for SaaS) that can ensure all of the individual pieces of your security policy are continuously being applied for user access. Can you accomplish all of this with a

traditional SSO vendor? Maybe. Okta's FastPass, for example, makes a determination of machine identity by validating a certificate that is installed on local devices, then determining the source IP address of the request. In most cases, however, FastPass would not be able to tell you more about the security inspection events present in that user's traffic, or anything else about the health of the end-user device. To this point, it is worth noting that your SSO provider is only as useful as the amount of data it can consume to make a policy decision.

If you decide that only machine certificates or only another measure of signal is appropriate for denoting a corporate device, this is totally appropriate at any stage of a business's security maturity — in fact, many businesses have yet to adopt device posture of any kind.

Another way to manage your sanctioned SaaS applications is to integrate with your Zero Trust vendor via API. Then, you can scan them for misconfiguration

or the presence of unexpected sensitive data. This process is independent of traditional Zero Trust access controls, but is offered by most Zero Trust vendors and can surface ongoing necessary configuration changes for all of your SaaS tools in a single view.

By evaluating the presence of sensitive data in SaaS applications that you manage, you can start to develop a sense of policy priority. Put another way, it may change the way that you think about what should be able to be accessed via BYOD vs. what should require authorized access from a managed endpoint. Or, conversely, how can you quantify the risk for BYOD access such that your users can be effectively conditioned?

Unsanctioned SaaS applications (Shadow IT)

The security model significantly changes when you move from SaaS applications you do control (i.e. can integrate with SSO and other third-party tools) to

applications you don't control. SaaS apps that fall into this category are often classified as 'unsanctioned' applications — sometimes, because they are managed by a secondary vendor that doesn't support SSO, or because they are services which haven't been explicitly approved by your IT organization for use. These unsanctioned apps are called shadow IT.

How do these apps proliferate within your environment? The logic is simple, especially with a startup. Users like to move quickly and may gravitate toward the most convenient method of getting their work across the finish line. Sometimes that can mean using tools that haven't been vetted or approved for use (or for potentially storing sensitive data).

Shadow IT is typically addressed as part of a general Internet security program, which sometimes falls within the same consideration set (or the same vendors) as a Zero Trust deployment. De-risking unsanctioned SaaS applications is almost always centered around visibility. The most important thing you can do — without

having things like SSO or your CASB tool integrated with an application — is understand the breadth of shadow IT usage.

Documenting unsanctioned applications usually requires using a forward-proxy tool like a DNS filter, secure web gateway, or some email-specific tooling. These tools can provide insights into which users have engaged with unsanctioned SaaS apps, and potentially even how they engaged with them (did they upload/download files, how much bandwidth have they transferred, etc.).

By implementing policies and strategies to document SaaS usage, you can start to form a better understanding of how your sensitive data is stored, moved, or manipulated within SaaS tools. Some businesses limit the use of SaaS to explicitly-approved corporate tools, while others are more lenient. There's no wrong approach, but building an early framework for how to capture usage information can help you

work backwards in the event that it becomes a pressing matter for your organization.

This framework can also give your IT organization direction on which tools to consider procurement cycles for. For example, if a critical mass of users already engages with a tool, it can sometimes make sense to get Enterprise capabilities for that tool to reduce the risk of shadow IT or allow your team to implement increased security features, sometimes without dramatically changing cost.

Where does Cloudflare fit in?

Cloudflare can help set a foundation for visibility and management of your [shadow IT](#) environment and subsequent discoveries. User traffic to the Internet can be audited and organized from the WARP client and our [Secure Web Gateway \(SWG\)](#), and can you understand where your sensitive data moves outside of your corporate-accepted SaaS tenants.

This can then be an opportunity to further expand your Zero Trust strategy by ensuring those newly-discovered tools are either explicitly blocked or explicitly allowed, setting specific data security controls on them, or integrating them with your Zero Trust vendor (using something like [Access for SaaS](#) to apply security policies).

Long-term management with APIs and Infrastructure as Code (IaC)

Many startups we speak to are ultimately concerned with the headcount and expertise required to manage security tooling that appears complex or overprovisioned for their use cases. Much of what they already do for development is managed through orchestration tools, Infrastructure as Code, and directly via API — but they often want to achieve a state of DevSecOps, where all Zero Trust (and other security

tooling) projects can be built, managed, and maintained as code.

While this is somewhat of an emerging concept for traditional security tooling, it should still be a critical consideration as you evaluate potential vendors. Keep in mind that although concepts like Terraform are supported by a number of Zero Trust vendors, these vendors may not support (or publish) provider or API endpoints for every concept in the product, which can lead to duplication or division in management efforts.

If your goal as an organization is to manage your networking and security stacks as code, it is important to start that framework early in your Zero Trust journey. While there may be challenges to navigate, getting a head start on network development will pay dividends as your business and security needs become inevitably more complex and difficult to manage.

As you continue to evaluate vendor partners for Zero Trust or general security initiatives, we recommend that you ensure that they have well-documented and

complete API endpoints for their entire product portfolio and management controls — as well as documentation for orchestration and Infrastructure as Code tools (like Terraform).

Where does Cloudflare fit in?

Cloudflare is very passionate about Zero Trust security in the context of DevSecOps. We build API-first as a primary ethos for all our products, and make all relevant API endpoints available to customers on the first day of feature availability, along with our extensive [documentation](#) ↗.

Separately, many of our customers manage their Cloudflare Zero Trust deployment without ever touching our dashboard; instead, they use Terraform or similar tools for their entire management plane. If this is the case for you, we have a comprehensive and complete [Terraform](#) provider to enable you to accomplish Zero Trust as Code.

Summary

In conclusion, making a few deliberate choices today about how your company approaches the basics of security and authentication will benefit your startup for years to come. The decisions you make now lay the foundation for a modern security infrastructure that will scale smoothly as your business grows. However you move forward, a few well-informed moves will ensure that your startup is built on sustainable, scalable Zero Trust security principles.

If you would like to discuss your Zero Trust requirements in greater detail and connect with one of our architects, visit

<https://www.cloudflare.com/cloudflare-one/>  and request a consultation.

Was this helpful?



[Previous](#) [Next](#)

[←](#)

Streamlined WAF deployment across zones and applications

[→](#)

Use mTLS with Cloudflare protected resources ↗

Last updated: Oct 9, 2025

Resources

[API](#)

[New to Cloudflare?](#)

[Directory](#)

[Sponsorships](#)

[Open Source](#)

Support

[Help Center](#)

[System Status](#)

[Compliance](#)

[GDPR](#)

Company

[cloudflare.com](#)

[Our team](#)

[Careers](#)

Tools

[Cloudflare Radar](#)

[Speed Test](#)

[Is BGP Safe Yet?](#)

[RPKI Toolkit](#)

[Certificate Transparency](#)

Community



© 2025 Cloudflare, Inc. • [Privacy Policy](#) • [Terms of Use](#)

• [Report Security Issues](#) • [Trademark](#) •  [Cookie Preferences](#)